

망분리를 풀면, 신뢰를 무엇으로 대체하는가

MLS 보상통제를 코드로 — 그리고 막는다는 사실을 매번 라이브로 재현.

검증 가능 72% (29/40)

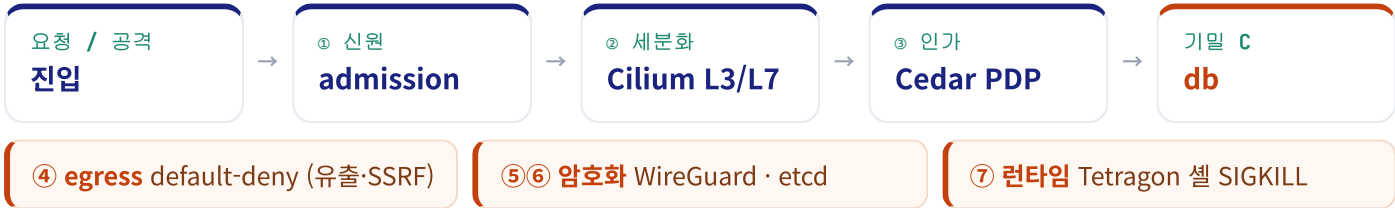
라이브 21/21

무료 로컬 · MIT

문 제

FSC 로드맵(2024-08-13)이 위치 기반 분리 → 위험 기반 MLS로 전환한다. "내부망 = 신뢰"가 사라진 자리를 보상통제로 메워야 하는데 — 실제로 막는지를 무엇으로 증명하나?

한 요청이 통과하는 6개 통제 계층



같은 경로·같은 L7 허용이라도 principal이 다르면 결과가 다르다 — alice 200 / bob 403.

증거 - 전부 재현 가능

72% (29/40)
검증가능성 커버리지

21/21
라이브 방어심층 검증

8/8 · 17/17
Cedar 인가 단위테스트

11/11
ReBAC (OpenFGA)

452 / 0
checkov pass / fail

CRITICAL 1
자체 검증이 잡은 실 버그 → 수정

21/21은 기능 회귀 스위트(분모 없는 측정 아님) · 72% 분모 = 40 · 갭(CONFIGURED 7·GOVERNANCE 2·NOT-COVERED 4)은 행 단위 공개.

왜 신뢰할 수 있나 — "안전하다"가 아니라 "갭을 공개한다"

재현 증거

감사자가 부작용 없는 dry-run으로 직접 거부/허용을 확인.

명시된 갭

미검증 항목을 행 단위로 공개 — 28%가 구체적이다.

정직성 증명

요청자 JWT 미강제 행을 스스로 추가해 헤드라인을 낮췄다 — 편한 숫자 대신 참값.

자동 채점기의 판정

```
alice → GET /accounts/acct-alice 200      bob → 같은 경로 403
db: /bin/sh rc=137 (SIGKILL)      db: id rc=0      web → db 000 (L3 drop)
```

[GitHub 저장소 →](#)

[무설치 체험 \(Codespaces\) →](#)

발표 자료·도입 가이드·FSC 매핑은 저장소에.

교육·포트폴리오 목적의 보상통제 설계 레퍼런스 — 법률/금융 자문도, 공식 FSC 컴플라이언스 매핑도 아닙니다. 규제 세부는 1차 출처 대조 필요 · 실 데이터스토어 없음 · 제3자 상표는 각 소유자 자산 · MIT